

DEVOPS E ARQUITETURA CLOUD

FASE 3 | AULA 07 -

ESTRATÉGIA DEVSECOPS: MÉTRICAS E MATURIDADE

SUMÁRIO

O QUE VEM POR AÍ?	3
HANDS ON	4
SAIBA MAIS.....	5
MERCADO, CASES E TENDÊNCIAS	10
O QUE VOCÊ VIU NESTA AULA?	11
REFERÊNCIAS.....	12

O QUE VEM POR AÍ?

A velocidade de *deployment* que o DevOps proporciona é uma vantagem competitiva inegável, mas ela exige uma nova e robusta camada de governança: a Observabilidade de Segurança. Quando se lidera projetos *cloud-native*, é imperativo não apenas entregar valor rapidamente, mas também garantir que cada entrega seja intrinsecamente segura e, acima de tudo, legalmente defensável em caso de auditoria.

Esta aula irá explorar como engenheiros de plataforma e arquitetos podem transformar o volume massivo de telemetria gerado pela infraestrutura em evidências sólidas para auditoria e conformidade regulatória. O foco é a implementação de um sistema que vá além do monitoramento reativo, permitindo construir uma postura de segurança proativa, rastreável e verificável.

HANDS ON

A teoria de governança de segurança que exploraremos converge diretamente para a prática de engenharia. O objetivo central será dominar a correlação de dados de múltiplas fontes, capacitando você a construir um *rastro digital* completo, confiável e legalmente defensável. Este é o momento de transformar os conceitos de Observabilidade, Rastreabilidade e Maturidade em ações concretas no seu pipeline.

Nossa jornada prática começará com a Observabilidade: você fará a instalação e configuração do Grafana, conectando-o ao AWS CloudWatch ou outras ferramentas para visualizar métricas de segurança, como bloqueios do AWS WAF, e construir *dashboards* de defesa ativa. Você irá focar na Auditoria e Rastreabilidade, onde você aprenderá a correlacionar logs do processo de CI/CD (GitHub Actions) com os logs de infraestrutura (AWS CloudTrail), materializando o *Non-repudiation* e atendendo aos requisitos críticos de atribuição de responsabilidade para a LGPD.

Na última etapa, será apresentado o conceito de Modelos de Maturidade, fornecendo um mapa para que você possa definir e justificar um *roadmap* de DevSecOps em um ambiente corporativo. Este bloco final integrará as soluções de Observabilidade e Auditoria vistas anteriormente, garantindo que você saiba como implementar estas práticas em grande escala.

SAIBA MAIS

A Tríade da Resiliência — Observabilidade, Auditoria e Conformidade no DevSecOps

A maturidade do DevSecOps não é medida apenas pela frequência de *deployment*, mas pela capacidade de provar que cada *deployment* é seguro, íntegro e, inequivocamente, rastreável. A adoção de arquiteturas *cloud-native* e de microsserviços elevou o volume e a complexidade dos dados de telemetria, exigindo que as organizações migrem do monitoramento tradicional para a Observabilidade em Segurança.

Observabilidade em Segurança: Unificando a Telemetria

Observabilidade é a disciplina que permite inferir o estado interno de um sistema a partir dos dados que ele emite: Métricas, Logs e Traces. Esta capacidade é crítica para a segurança, pois permite responder a perguntas *novas* sobre o comportamento anômalo de um sistema, essencial para detectar ataques sofisticados ou desvios de políticas não antecipados.

Em ambientes complexos, o Grafana emerge como a camada de agregação de inteligência, atuando como um *Single Pane of Glass* para a postura de segurança. Ele permite unificar a visão de diferentes fontes de dados, como o AWS CloudWatch, que é a fonte nativa de métricas e logs para serviços AWS. Ao conectar o Grafana ao CloudWatch, é possível construir *dashboards* especializados. Por exemplo, a análise de um Web Application Firewall (WAF), como o AWS WAF, vai além de apenas tê-lo ativo: o valor reside em analisar padrões de ataques bloqueados em tempo real, visualizando métricas como a contagem de *requests* bloqueados, a taxa de sucesso dos ataques e a geolocalização da origem dos bloqueios, transformando a observabilidade em um mecanismo de defesa ativa.

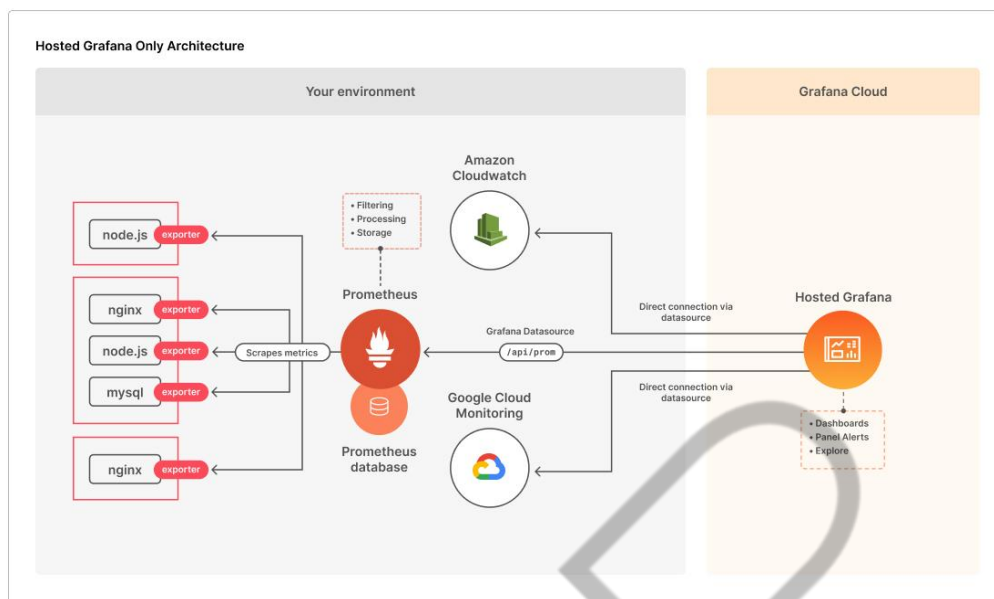


Figura 1 – Arquitetura Grafana
Fonte: [Grafana](#) (2025)

Ferramentas Avançadas de Log Analytics: Otimização de Custos e Análise Forense

A eficiência na análise de logs é uma prioridade, dada a complexidade e o volume de dados. Ferramentas de *log analytics* modernas são essenciais para extrair contexto e valor de forma rápida e custo-efetiva.

O **AWS CloudWatch Logs Insights** é uma ferramenta analítica otimizada para o ecossistema AWS, utilizando uma linguagem de consulta rica que suporta sintaxe similar a SQL. Sua principal força é a integração nativa, permitindo varrer logs em larga escala de diversos serviços AWS, como AWS CloudTrail e Lambda, de forma centralizada. É uma ferramenta poderosa para correlação de dados e análise *on-demand* de anomalias, como padrões incomuns de acesso, fundamental para monitoramento de segurança.

Em contraste, o **Grafana Loki** é construído para ser um sistema de agregação de logs de baixo custo, que indexa os dados primariamente por metadados (*labels*), realizando o processamento do conteúdo da linha de log (*payload*) somente no momento da consulta (*schema-on-read*). Sua linguagem, o LogQL, permite buscas eficientes e, o que é mais estratégico, a **geração de métricas a partir de logs**. Essa funcionalidade, usando funções de agregação

como `rate` e `quantile_over_time`, permite que a Observabilidade de Logs seja utilizada para alertas de desempenho e segurança. A escolha entre eles reside no *trade-off* arquitetural: integração nativa e recursos avançados de anomalias (CloudWatch) versus otimização de custos e flexibilidade multi-cloud (Loki).



Figura 2 – Grafana Loki
Fonte: [Grafana](#) (2025)

Rastreabilidade, Non-Repudiation e o Rigor da LGPD

A Auditoria no DevSecOps é a garantia contínua de que as ações de *deployment* e alteração de infraestrutura são atribuíveis e legalmente defensáveis.

O **Non-repudiation** (Não-Repúdio) é o princípio de segurança que impede que um indivíduo negue a autoria de uma ação. No ciclo de vida do *software*, isso significa provar, de forma irrefutável, que o código que está em produção foi escrito, revisado, aprovado e *deployado* por entidades conhecidas. Isso exige mecanismos técnicos como o uso de assinaturas digitais para validar a integridade dos artefatos e logs de auditoria imutáveis.

Para cumprir a **LGPD**, que impõe exigências rigorosas de rastreabilidade para dados pessoais e identificadores indiretos (como endereços IP), é fundamental correlacionar o "rastro digital" em três camadas:

1. **Fonte e Revisão:** logs de *Pull Requests* e *workflows* do GitHub Actions.
2. **Execução do Pipeline:** logs da plataforma de CI/CD que detalham a execução do *build* e do *deployment*.
3. **Infraestrutura:** logs de auditoria como o AWS CloudTrail, que registram todas as chamadas de API.

Esta correlação é a única forma de garantir a **cadeia de custódia** em um processo automatizado. A falha em manter esse rastro representa uma falha grave de governança. Por isso, a **Conformidade como Código (Compliance as Code)** se torna a única estratégia escalável, incorporando checagens de segurança e privacidade diretamente nos *pipelines*.

SLSA: O Padrão de Integridade da Cadeia de Suprimentos

O SLSA (*Supply-chain Levels for Software Artifacts*) é o padrão industrial incremental, desenvolvido pela OpenSSF, para garantir a segurança da cadeia de suprimentos de *software*.

A *proveniência* é a peça central do SLSA: metadados verificáveis que descrevem onde, quando e como o artefato de *software* foi produzido. Esta proveniência, que deve ser assinada pelo sistema de *build* (e não pelo desenvolvedor), associa o binário final ao seu código-fonte e aos passos exatos do *build*, garantindo a integridade contra adulteração.

Para o arquiteto, o ponto de maior complexidade é o requisito para atingir o **SLSA Nível 3**, que exige um **Isolated Build Environment** (Ambiente de Build Isolado). O serviço de *build* deve garantir que as etapas de construção ocorram em um ambiente efêmero, livre de influência de outras instâncias. Este isolamento:

1. Impede que o *build* acesse segredos do serviço (como a chave de assinatura da proveniência).
2. Previne a persistência ou a influência de *malware* entre *builds*.
3. Exige que caches sejam puramente endereçáveis por conteúdo (*content-addressable*) para prevenir adulteração.

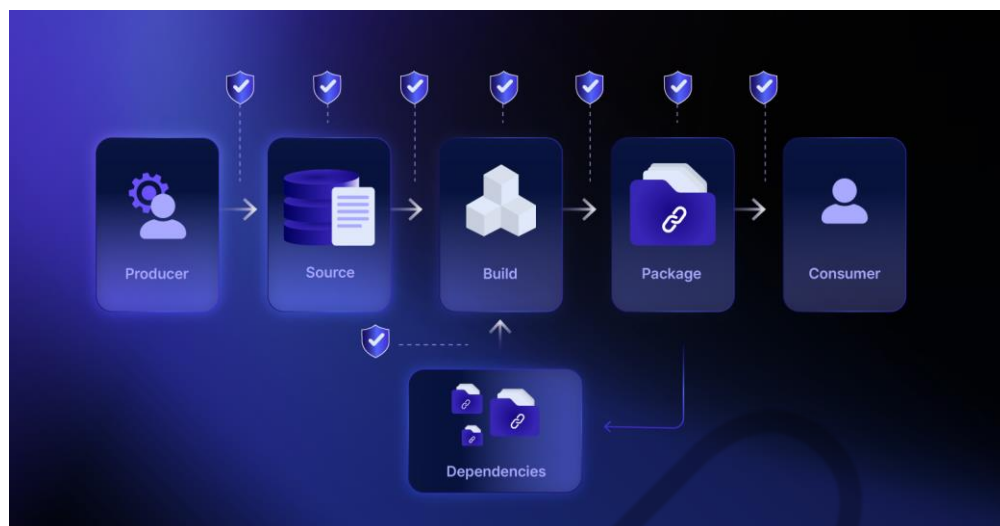


Figura 3 – SLSA
Fonte: [Grafana](#) (2025)

A implementação do SLSA Nível 3 em grande escala é o principal motor por trás da **Engenharia de Plataformas**. Esta disciplina centraliza a complexidade, oferecendo o *build* isolado e a proveniência assinada como um serviço padrão e simples para todas as pessoas desenvolvedoras.

MERCADO, CASES E TENDÊNCIAS

A transição para o DevSecOps, com sua demanda por Observabilidade exaustiva e Conformidade verificável, é uma resposta direta à crescente complexidade das arquiteturas multi-nuvem e à escalada de ameaças à cadeia de suprimentos.

Modelos de Maturidade e a Governança Estruturada

Em grandes corporações, a implementação do DevSecOps deve ser estruturada. Modelos de maturidade fornecem uma metodologia essencial para líderes de tecnologia, atuando como um guia para responder a três perguntas fundamentais: Onde a organização se encontra? Qual nível de maturidade é exigido pelos requisitos de negócio e regulatórios? E qual é o *roadmap* tático para preencher essa lacuna? O foco no controle da conformidade, impulsionado por regulamentações, está forçando o mercado a adotar o DevSecOps de forma acelerada. Este alinhamento entre planos de segurança e requisitos de governo não apenas mitiga riscos, mas também constrói confiança com *stakeholders* e clientes.

Cases de Referência em Observabilidade e Automação

A análise qualitativa de casos de sucesso ilustra a transformação que a Observabilidade de Segurança e a automação trazem. Empresas de streaming global que lidam com um volume imenso de transações e vastas infraestruturas de microsserviços utilizam o DevSecOps para gerenciar a escala. A integração de *scanners* de segurança automatizados e ferramentas de monitoramento em tempo real diretamente nos *pipelines* permitiu a essas organizações aumentar a frequência de *deployment* sem que a segurança se tornasse um gargalo. A utilização de automação para garantir a rastreabilidade (Non-repudiation) em cada *deployment* é um requisito crucial para manter a confiança.

O QUE VOCÊ VIU NESTA AULA?

Nesta aula fundamental, o foco foi a tríade estratégica de Observabilidade, Auditoria e Conformidade, essenciais para a governança de DevSecOps em nível corporativo. Você compreendeu como o Grafana atua como uma camada unificada de inteligência, capaz de integrar e correlacionar métricas de segurança para monitoramento proativo.

O conteúdo aprofundou as diferenças estratégicas entre soluções de análise de logs, como o AWS CloudWatch Logs Insights e o Grafana Loki/LogQL, destacando as implicações de custos e arquitetura na escolha do melhor modelo de indexação.

Foi estabelecida a conexão crítica entre a rastreabilidade digital do DevOps e os requisitos regulatórios, enfatizando a importância do Non-repudiation e da correlação de logs de *source* (GitHub Actions), *pipeline* e infraestrutura (CloudTrail) para atender à LGPD. Por fim, analisamos o framework SLSA como o padrão para garantir a integridade da cadeia de suprimentos, e você aprendeu a utilizar Modelos de Maturidade para planejar a adoção corporativa, com a Engenharia de Plataformas posicionada como o vetor estratégico para a segurança e a agilidade em grande escala.

REFERÊNCIAS

CHECKPOINT. **DevSecOps Maturity Model**. 2025. Disponível em: <https://www.checkpoint.com/pt/cyber-hub/cloud-security/devsecops/devsecops-maturity-model/>. Acesso em: 01 dez. 2025.

GRAFANA LABS. **LogQL**. 2025. Disponível em: <https://grafana.com/docs/loki/latest/query/>. Acesso em: 01 dez. 2025.

RUIZ, V. S. **Conformidade contínua com LGPD, PCI DSS e NIS2**. 2025. Disponível em: <https://activesys.com.br/blog/conformidade-pipelines-lgpd-pci-nis2>. Acesso em: 01 dez. 2025.

SLSA. **SLSA (Supply-chain Levels for Software Artifacts)**. 2025. Disponível em: <https://slsa.dev/spec/v1.2/>. Acesso em: 01 dex. 2025.

WIZ. **The four SLSA security levels**. 2025. Disponível em: <https://www.wiz.io/academy/slsa-framework>. Acesso em: 01 dez. 2025.

PALAVRAS-CHAVE

Observabilidade. DevSecOps. Auditoria. Conformidade. LGPD. Rastreabilidade. Non-repudiation. Grafana. AWS CloudWatch Insights. Loki. LogQL. SLSA. Supply Chain Security. Modelo de Maturidade. Engenharia de Plataformas.

EMANIP



POS TECH